

Security Controls: Prevent, Detect, Respond

The Three Control Categories

Category	What It Protects	Examples
Administrative	People & process	policies, training, background checks, change control
Technical	Systems & data	firewalls, AV/EDR, encryption, MFA, SIEM
Physical	Buildings & devices	locks, cameras, badges, server-room air-gap

Function: Prevent / Detect / Respond

Controls also have a FUNCTION:

Prevent – stop it happening: firewall, patch, MFA, policy

Detect – notice it happening: EDR, SIEM, IDS, logging, alerts

Respond – handle it after: IR plan, backups, containment, recovery

Deter – discourage: banners ("authorized use only"), logging posters

A good security program is not "more prevention". It's balanced prevention + detection + response. Prevention fails eventually – that's when detect+respond saves you.

Defense in Depth (The Onion)

Layers around each asset:

People/Policy – least privilege, training

Perimeter – firewall, WAF, IDS

Network – segmentation, VLANs

Host – hardening, EDR, patching

Application – secure coding, CSP

Data – encryption, DLP, backups

People again – the human layer (phishing resistance)

An attacker that defeats the firewall still meets the EDR, the encryption, and the air-gapped backups.

The Control-to-CIA Mapping

Every control should map to a CIA property + an asset:

Control	CIA Property	Comment
MFA	Confidentiality	blocks credential misuse
Hash	Integrity	detects modification
Redundancy/backups	Availability	survives failure
Digital signature	Non-repudiation	proves sender
Audit logging	Accountability	proves actions

Analyst habit: when someone says "we have a control", ask three questions: *Prevent, detect or respond? Which CIA property? For which asset?* If they can't answer, the control is cosmetic.

[← Risk Management & Threat Mod...](#)

[Security Roles & Career Landsc...](#)